

Data Types and Classifications

Data Types:

Regulated:

- Managed by a third party
- Government laws and statutes

Trade secret;

- An organization's secret formulas
- Often unique to an organization

Intellectual property:

- May be publicly visible
- Copyright and trademark restrictions

Legal information::

- Court records and documents, judge and attorney info
- PII and other sensitive details
- Usually stored in many different systems

Financial information:

- Internal company financial details
- Customer financials
- Payment records
- Credit card data, bank records, etc

Human readable:

- Humans can understand the data
- Very clear and obvious

Non human readable:

- Not easily understood by humans
- Encoded data
- Bar codes
- Images

Some formats are a hybrid:

- CSV, XML, JSON, etc.

Classifying sensitive data;

Not all data has the same level of categorization:

- License tag numbers vs health records

Different levels require different security and handling:

- Additional permissions
- A different process to view
- Restricted network access

Data classifications:

- Data that is the property of an organization

- May also include trade secrets
- Often data unique to the org

PII -Personally Identifiable information:

- Data can used to identify a person
- Name, birth date etc.

PHI - Protected Health information;

- Health information associated with an individual
- Health status, health care records, payments etc.

Data classifications:

Sensitive:

- Intellectual property, PII, PHI

Confidential:

- Very sensitive, must be approved to view

Public / unclassified:

- anyone can view it

Private / classified / restricted:

- Restricted access, may require an NDA

Critical:

- Data should always be accessible.

States of Data

Data at rest:

The data is on a storage device:

- Hard drive, ssd, etc.

Encrypt the data:

- Whole disk encryption
- Data base encryption
- File or folder level encryption

Apply permissions:

- Access control lists
- Only authorized users can access the data

Data in transit;

Data that's being transmitted over the network:

- Also called data in motion

Not much protection as it travels;

- Many different switches, router and devices

Network based protection:

- Firewall, IPS

Provide transport encryption:

- TLS (transport layer security)
- IPSec (internet protocol security)

Data in Use:

Data is actively processing in memory:

- System RAM, CPU registers and cache

The data is almost always decrypted:

- Otherwise you couldn't do anything with it

The attackers can pick the decrypted information out of ram:

- A very attractive option

Target corp breach - November of 2013:

- 110 million credit cards stolen
- Data in transit encryption and data at rest encryption
- Attackers picked the credit card numbers out of the point of sale RAM

Data Sovereignty:

- Data that resides in a country is subject to the laws in that country
- Legal monitoring, court orders, etc

Laws may prohibit data is stored:

- GDPR (General Data Protection Regulation)
- Data collected on EU citizens must be stored in the EU

Basically if your data is stored in different countries you have to abide by that countries rules

Geolocation:

Location details:

- Tracks within a localized area

Many ways to determine location:

- 802.11, mobile providers, GPS

Can be used to manage data access:

- Prevent access from other countries

Limit admin tasks unless secure areas is used:

- Permit enhanced access when inside the building

Protecting data

Geographic restrictions:

Network location:

- Identify based on IP subnet
- Can be difficult with mobile devices

Geolocation - Determine users location:

- GPS
- 802.11 wireless, less accurate
- IP addresses, not very accurate

Geofencing:

- Automatically allow or restrict access when the user s in a particular location
- Dont allow this app to run unless you're near the office

Protecting Data is our job obviously

Data is everywhere:

- Storage device
- On network
- Cpu
- Etc

Protecting the data;

- Encrypt data, security polices

Data permissions:

- Not everyone has the same access

Encryption:

Encode information. To make it unreadable:

- Original information is plain text, encrypted form is cipher text

This is a top way street:

- Convert between one and the other
- If you have the proper key

Confusion;

- The encrypted data is drastically different than plain text

Hashing:

Represents data as a string of text;

- A message digest, a fingerprint

One way trip:

- Impossible to recover the original message form the digest
- Used to store passwords / confidentiality

Verify downloaded doc is the same as the original:

- Integrity

Can be a digital signature:

- Authentication, non repudiation, and integrity

Will not have a collision:

- different messages will not hav the same hash

SHA256 hash algorithm:

- 256 bits / 64 hexadecimal characters

Obfuscation:

Camo

Hide code or messages.

Data masking:

- A type of obfuscation
- When all the numbers are stars except the last 4

The data may still be intact in storage but won't be seen to us

Tokenization:

Replaces sensitive data with a non sensitive placeholder:

- SSN 266-12-1112 is now 691-61-8539

Common with credit card processing:

- Uses temp token
- Only lasts one use.

Doesn't use encryption or hashing it just sends int because after its used its useless

Segmentation

Most orgs use one big data base

One breach put all data at risk

Separate date into different locations

All these different places should be placed should have different decreeing levels of security based on how confidential the data is.

Permission restrictions:

- Not everyone should be an admin